

**Research and Development for
Space Data System Standards**

**INTERGOVERNMENTAL
CERTIFICATION
AUTHORITY**

EXPERIMENTAL SPECIFICATION

CCSDS 357.1-O-1

**ORANGE BOOK
December 2024**

**Research and Development for
Space Data System Standards**

**INTERGOVERNMENTAL
CERTIFICATION
AUTHORITY**

EXPERIMENTAL SPECIFICATION

CCSDS 357.1-O-1

ORANGE BOOK
December 2024

AUTHORITY

Issue:	Orange Book, Issue 1
Date:	December 2024
Location:	Washington, DC, USA

This document has been approved for publication by the Consultative Committee for Space Data Systems (CCSDS). The procedure for review and authorization of CCSDS documents is detailed in *Organization and Processes for the Consultative Committee for Space Data Systems* (CCSDS A02.1-Y-4).

This document is published and maintained by:

CCSDS Secretariat
National Aeronautics and Space Administration
Washington, DC, USA
Email: secretariat@mailman.ccsds.org

FOREWORD

Intergovernmental Certification Authority will harmonize the credentialing process for unclassified interactions between space agencies and spacecraft.

Attention is drawn to the possibility that some of the elements of this document may be the subject of patent rights. CCSDS has processes for identifying patent issues and for securing from the patent holder agreement that all licensing policies are reasonable and non-discriminatory. However, CCSDS does not have a patent law staff, and CCSDS shall not be held responsible for identifying any or all such patent rights.

Through the process of normal evolution, it is expected that expansion, deletion, or modification of this document may occur. This Experimental Specification is therefore subject to CCSDS document management and change control procedures, which are defined in the *Organization and Processes for the Consultative Committee for Space Data Systems* (CCSDS A02.1-Y-4). Current versions of CCSDS documents are maintained at the CCSDS Web site:

<http://www.ccsds.org/>

Questions relating to the contents or status of this document should be sent to the CCSDS Secretariat at the email address indicated on page i.

At time of publication, the active Member and Observer Agencies of the CCSDS were:

Member Agencies

- Agenzia Spaziale Italiana (ASI)/Italy.
- Canadian Space Agency (CSA)/Canada.
- Centre National d'Etudes Spatiales (CNES)/France.
- China National Space Administration (CNSA)/People's Republic of China.
- Deutsches Zentrum für Luft- und Raumfahrt (DLR)/Germany.
- European Space Agency (ESA)/Europe.
- Federal Space Agency (FSA)/Russian Federation.
- Instituto Nacional de Pesquisas Espaciais (INPE)/Brazil.
- Japan Aerospace Exploration Agency (JAXA)/Japan.
- National Aeronautics and Space Administration (NASA)/USA.
- UK Space Agency/United Kingdom.

Observer Agencies

- Austrian Space Agency (ASA)/Austria.
- Belgian Science Policy Office (BELSPO)/Belgium.
- Central Research Institute of Machine Building (TsNIIMash)/Russian Federation.
- China Satellite Launch and Tracking Control General, Beijing Institute of Tracking and Telecommunications Technology (CLTC/BITTT)/China.
- Chinese Academy of Sciences (CAS)/China.
- China Academy of Space Technology (CAST)/China.
- Commonwealth Scientific and Industrial Research Organization (CSIRO)/Australia.
- Danish National Space Center (DNSC)/Denmark.
- Departamento de Ciência e Tecnologia Aeroespacial (DCTA)/Brazil.
- Electronics and Telecommunications Research Institute (ETRI)/Korea.
- Egyptian Space Agency (EgSA)/Egypt.
- European Organization for the Exploitation of Meteorological Satellites (EUMETSAT)/Europe.
- European Telecommunications Satellite Organization (EUTELSAT)/Europe.
- Geo-Informatics and Space Technology Development Agency (GISTDA)/Thailand.
- Hellenic National Space Committee (HNSC)/Greece.
- Hellenic Space Agency (HSA)/Greece.
- Indian Space Research Organization (ISRO)/India.
- Institute of Space Research (IKI)/Russian Federation.
- Korea Aerospace Research Institute (KARI)/Korea.
- Ministry of Communications (MOC)/Israel.
- Mohammed Bin Rashid Space Centre (MBRSC)/United Arab Emirates.
- National Institute of Information and Communications Technology (NICT)/Japan.
- National Oceanic and Atmospheric Administration (NOAA)/USA.
- National Space Agency of the Republic of Kazakhstan (NSARK)/Kazakhstan.
- National Space Organization (NSPO)/Chinese Taipei.
- Naval Center for Space Technology (NCST)/USA.
- Netherlands Space Office (NSO)/The Netherlands.
- Research Institute for Particle & Nuclear Physics (KFKI)/Hungary.
- Scientific and Technological Research Council of Turkey (TUBITAK)/Turkey.
- South African National Space Agency (SANSAT)/Republic of South Africa.
- Space and Upper Atmosphere Research Commission (SUPARCO)/Pakistan.
- Swedish Space Corporation (SSC)/Sweden.
- Swiss Space Office (SSO)/Switzerland.
- United States Geological Survey (USGS)/USA.

PREFACE

This document is a CCSDS Experimental Specification. Its Experimental status indicates that it is part of a research or development effort based on prospective requirements, and as such it is not considered a Standards Track document. Experimental Specifications are intended to demonstrate technical feasibility in anticipation of a ‘hard’ requirement that has not yet emerged. Experimental work may be rapidly transferred onto the Standards Track should a hard requirement emerge in the future.

DOCUMENT CONTROL

Document	Title	Date	Status
CCSDS 357.1-O-1	Intergovernmental Certification Authority, Experimental Specification, Issue 1	December 2024	Original issue

CONTENTS

<u>Section</u>	<u>Page</u>
1 INTRODUCTION	1-1
1.1 PURPOSE AND SCOPE	1-1
1.2 STRUCTURE OF THIS DOCUMENT	1-1
1.3 PURPOSE OF THE DOCUMENT	1-2
1.4 SCOPE OF THE DOCUMENT	1-2
1.5 CONVENTIONS AND DEFINITIONS	1-3
1.6 REFERENCES	1-6
2 INTERGOVERNMENTAL CREDENTIAL AUTHORITY	2-1
2.1 INTRODUCTION	2-1
2.2 PRIVATE KEY ENCRYPTION AND ITS RELATION TO A CA	2-1
2.3 IGCA CONCEPT	2-2
2.4 IGCA DESCRIPTION	2-3
2.5 GENERAL CONSTRAINTS	2-5
2.6 POST-QUANTUM ENCRYPTION CONSIDERATIONS	2-5
3 REQUIREMENTS	3-1
3.1 OVERVIEW	3-1
3.2 POLICY REQUIREMENTS	3-1
3.3 QUALITY REQUIREMENTS	3-3
3.4 TECHNICAL VETTING REQUIREMENTS FOR ISSUING CAS	3-5
3.5 OPERATIONAL VERIFICATION	3-6
3.6 DOCUMENTATION	3-6
ANNEX A IMPLEMENTATION CONFORMANCE STATEMENT PROFORMA (NORMATIVE)	A-1
ANNEX B SECURITY, SANA, AND PATENT CONSIDERATIONS (INFORMATIVE)	B-1
ANNEX C POSSIBLE IMPLEMENTATION EXAMPLE (INFORMATIVE)	C-1
ANNEX D DEFINITION OF ACRONYMS (INFORMATIVE)	D-1

Figure

2-1 Asymmetric Key Use in Relation to a Certificate Authority	2-1
2-2 IGCA Operations Enable the Security Interconnection Services	2-2
2-3 Illustration of the CA Functions and Their Operational Use	2-4

1 INTRODUCTION

1.1 PURPOSE AND SCOPE

Certificate Authorities (CAs) are trusted third-party entities that create, issue, store, and sign digital certificates. These digital certificates are afforded both integrity and authentication by virtue of the CA digital signature on the certificate. As a result, the authentication and integrity of the information contained in the certificate is assured as long as the CA, and the root certificates they generate, are secure and uncompromised.

A digital certificate binds an identity to a public key using a digital signature. A digital certificate establishes the identity of the owner of the certificate and is used to distribute the owner's public key.

When a certificate is signed by a trusted CA, the public key in the certificate can be used to establish secure communications with another entity or to validate information that has been digitally signed. Certificates contain an owner's identity (e.g., individual's name, hostname, organization) and a public key. Certificates enable secure connectivity between entities, providing confidentiality, authenticity, and integrity.

When secure communication is required, an entity uses either a cached copy of another entity's certificate or attempts to obtain a certificate for that entity from a CA. The communicating entities use the public keys contained in the certificates to communicate with each other using asymmetric cryptographic methods or to generate a symmetric key via a key agreement protocol, ensuring the authentication, integrity, and confidentiality of the exchanged information.

From a CCSDS space mission perspective, substantial coordination is required to establish secure connections between Agencies, or between Agencies and their commercial partners, and specified endpoints for cross support and interoperability. An *Intergovernmental Certification Authority* (IGCA) enables coordination and connection and provides secure validation processes between entities in space or on the ground. Certificates may be used to provide secure identities for systems, software, spacecraft, instruments, ground stations, relay spacecraft, people, and other entities that may participate in space systems.

1.2 STRUCTURE OF THIS DOCUMENT

This subsection describes the structure of this document. Section 1 is the introduction, including the purpose and scope of the document. Section 2 describes the IGCA and its intended operations. Section 3 provides the specifications for the creation and operation of the IGCA. The annexes provide the Implementation Conformance Statement; and Security, SANA, and Patent Considerations; and Definition of Acronyms.

1.3 PURPOSE OF THE DOCUMENT

This document specifies the requirements for an IGCA. This document establishes the requirements for governing, administrating, and operating an IGCA.

The requirements described in this document provide the structure of management and governance for the use of the digital credentials documented in *CCSDS Authentication Credentials* (reference [3]), which are the basis for security services authentication, confidentiality, integrity, and nonrepudiation.

This document also specifies requirements for the development of a CCSDS Public Key Infrastructure (PKI). It defines the terms and conditions under which the IGCA and affiliated CAs operate. It defines how the IGCA can serve as a CA Bridge between member space agencies and enable CAs to issue digitally signed certificates that can be used to secure access and communications paths.

1.4 SCOPE OF THE DOCUMENT

This document describes the overall business, legal, and technical infrastructure of the IGCA and specifies requirements for the following:

- appropriate applications for, and the assurance levels associated with CCSDS-issued digital certificates;
- obligations of CAs;
- requirements for audit and related security reviews;
- methods to confirm the identity of certificate applicants;
- operational procedures for certificate lifecycle services:
 - certificate application,
 - issuance,
 - acceptance,
 - revocation,
 - expiration,
 - storage, and
 - renewal;
- operational security procedures for audit logging, records retention, and disaster recovery;
- physical, personnel, key management, and logical security; and
- certificate profile and Certificate Revocation List (CRL) contents.

1.5 CONVENTIONS AND DEFINITIONS

1.5.1 NORMATIVE TEXT

The following conventions apply for the normative specifications in this Experimental Specification:

- a) the words ‘shall’ and ‘must’ imply a binding and verifiable specification;
- b) the word ‘should’ implies an optional, but desirable, specification;
- c) the word ‘may’ implies an optional specification;
- d) the words ‘is’, ‘are’, and ‘will’ imply statements of fact.

NOTE – These conventions do not imply constraints on diction in text that is clearly informative in nature.

1.5.2 INFORMATIVE TEXT

In the normative sections of this document, informative text is set off from the normative specifications either in notes or under one of the following subsection headings:

- Overview;
- Background;
- Rationale;
- Discussion.

1.5.3 DEFINITIONS

For the purposes of this document, the following definitions apply.

NOTE – The following definitions are unique to this Intergovernmental Certification Authority Experimental Specification and do not appear in the CCSDS Information Security Glossary (reference [5]). Some definitions are sourced from the CA/Browser Forum (reference [1]).

applicant: The natural person or legal entity that applies for (or seeks renewal of) a certificate. Once the certificate is issued, the applicant is referred to as the Subscriber. For certificates issued to devices, the applicant is the entity that controls or operates the device named in the certificate, even if the device is sending the actual certificate request.

audit report: A report from a qualified auditor stating the qualified auditor’s opinion on whether an entity’s processes and controls comply with the mandatory provisions of these Requirements.

Bridge: An agency or corporation whose CA is cross certified, allowing that agency or corporation issuing CA to issue valid and interoperable certificates.

certification practice statement, CPS: One of several documents forming the governance framework under which certificates are created, issued, managed, and used.

control (and its correlative meanings, ‘controlled by’ and ‘under common control with’): Possession, directly or indirectly, of the power to: (1) direct the management, personnel, finances, or plans of such entity; (2) control the election of a majority of the directors; or (3) vote that portion of voting shares required for ‘control’ under the law of the entity’s Jurisdiction of Incorporation or Registration but in no case less than 10 percent.

cross certificate: A certificate that is used to establish a trust relationship between two Root CAs.

expiry date: The ‘not after’ date in a certificate that defines the end of a certificate’s validity period.

government entity: A government-operated legal entity, agency, department, ministry, branch, or similar element of the government of a country, or political subdivision within such country (such as a state, province, city, county, etc.).

legal entity: An association, corporation, partnership, proprietorship, trust, government entity, or other entity with legal standing in a country’s legal system.

nation state: A bounded sovereign polity.

object identifier, OID: A unique alphanumeric or numeric identifier registered under the International Organization for Standardization’s (ISO’s) applicable standard for a specific object or object class.

qualified auditor: A natural person, legal entity, or group of natural persons or legal entities that collectively possess the following qualifications and skills:

- independence from the subject of the audit;
- the ability to conduct an audit that addresses the criteria specified in an Eligible Audit Scheme;
- employment of individuals who have proficiency in examining PKI technology, information security tools and techniques, information technology and security auditing, and the third-party attestation function;
- (for audits conducted in accordance with any one of the European Telecommunications Standards Institute (ETSI) standards) accreditation in accordance with ISO 17065 applying the requirements specified in ETSI EN 319 403;
- (for audits conducted in accordance with the WebTrust® standard) being licensed by WebTrust®;

- bound by law, government regulation, or professional code of ethics;
- except in the case of an Internal Government Auditing Agency, maintaining Professional Liability/Errors & Omissions insurance.

registration authority, RA: An entity that is responsible for one or more of the following functions: the identification and authentication of certificate applicants, the approval or rejection of certificate applications, initiating certificate revocations or suspensions under certain circumstances, processing subscriber requests to revoke or suspend their certificates, and approving or rejecting requests by subscribers to renew or rekey their certificates. RAs, however, do not sign or issue certificates (reference [13]).

relying party: Any natural person or legal entity that relies on a valid certificate. An Application Software Supplier is not considered a relying party when software distributed by such Supplier merely displays information relating to a certificate.

Root CA: The top-level Certification Authority whose root certificate is distributed by Application Software Suppliers and that issues subordinate CA certificates.

root certificate: The self-signed certificate issued by the Root CA to identify itself and to facilitate verification of certificates issued to its subordinate CAs.

subject: The natural person, device, system, unit, or legal entity identified in a certificate as the subject. The subject is either the Subscriber or a device under the control and operation of the Subscriber.

subject identity information: Information that identifies the certificate subject in the X.509 certificate. subject identity information does not include a domain name listed in the subjectAltName extension or the Subject commonName field.

subordinate CA: A Certification Authority whose certificate is signed by the Root CA or another subordinate CA.

subscriber: A natural person or legal entity to whom a certificate is issued and who is legally bound by a subscriber agreement or terms of use.

subscriber agreement: An agreement between the CA and the applicant/subscriber that specifies the rights and responsibilities of the parties.

terms of use: Provisions regarding the safekeeping and acceptable uses of a certificate issued in accordance with these Requirements when the applicant/subscriber is an Affiliate of the CA or is the CA.

valid certificate: A certificate that passes the validation procedure specified in RFC 5280 (reference [15]).

validity period: The period of time measured from the date when the certificate is issued until the expiry date.

1.6 REFERENCES

The following publications contain provisions that, through reference in this text, constitute provisions of this Experimental Specification. At the time of publication, the editions indicated were valid. All publications are subject to revision, and users of this Experimental Specification are encouraged to investigate the possibility of applying the most recent editions of the documents indicated here. The CCSDS Secretariat maintains a register of currently valid CCSDS publications.

- [1] *Baseline Requirements for the Issuance and Management of Publicly-Trusted Certificates*. Version 2.0.1. N.p.: CA/Browser Forum, 17 August 2023.
- [2] *Security Threats against Space Missions*. Issue 3. Report Concerning Space Data System Standards (Green Book), CCSDS 350.1-G-3. Washington, D.C.: CCSDS, February 2022.
- [3] *CCSDS Authentication Credentials*. Issue 1. Recommendation for (Blue Book), CCSDS 357.0-B-1. Washington, D.C.: CCSDS, July 2019.
- [4] *WebTrust Principles and Criteria for Certification Authorities*. Version 2.2. Toronto, Ontario, Canada: CPA Canada, 1 May 2019.
- [5] *Information Security Glossary of Terms*. Issue 3. Recommendation for Space Data System Practices (Magenta Book), CCSDS 350.8-M-3. Washington, D.C.: CCSDS, February 2024.
- [6] *International Standard on Assurance Engagements—ISAE 3000 (Revised)—Assurance Engagements Other Than Audits or Reviews of Historical Financial Information*. Revised [December 2015]. New York: IFAC, December 2013.
- [7] *Information Technology—Security Techniques—Entity Authentication Assurance Framework*. ISO/IEC 29115:2013. Geneva: ISO, 2013.
- [8] *CCSDS Cryptographic Algorithms*. Issue 2. Recommendation for Space Data System Standards (Blue Book), CCSDS 352.0-B-2. Washington, D.C.: CCSDS, August 2019.
- [9] R. Barnes, et al. *Automatic Certificate Management Environment (ACME)*. RFC 8555. Reston, Virginia: ISOC, March 2019.
- [10] *Security Requirements for Cryptographic Modules*. Federal Information Processing Standards Publication 140-3. Gaithersburg, Maryland: NIST, 22 March 2019.
- [11] *Intellectual Property Rights Policy*. Version 1.3. N.p.: CA/Browser Forum, 3 July 2018.
- [12] “Deed—Attribution 4.0 International.” Creative Commons.
<https://creativecommons.org/licenses/by/4.0/>.

- [13] S. Chokhani, et al. *Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework*. RFC 3647. Reston, Virginia: ISOC, November 2003.
- [14] *The Future Lunar Communications Architecture*. Version 1.3. Report of the Interagency Operations Advisory Group Lunar Communications Architecture Working Group. Washington, DC: IOAG, 31 January 2022.
- [15] D. Cooper, et al. *Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile*. RFC 5280. Reston, Virginia: ISOC, May 2008.
- [16] Dustin Moody. "Update on the NIST Post-Quantum Cryptography Project." NIST Computer Security Resource Center.
https://csrc.nist.gov/CSRC/media/Presentations/Update-on-the-NIST-Post-Quantum-Cryptography-Proje/images-media/2_post-quantum_dmooddy.pdf.
- [17] *PKCS #3: Diffie-Hellman Key-Agreement Standard*. Version 1.4. An RSA Laboratories Technical Note. Burlington, Massachusetts: RSA, 1 November 1993.
- [18] *PKCS #1 v2.1: RSA Cryptography Standard*. Version 1.4. An RSA Laboratories Technical Note. Burlington, Massachusetts: RSA, 14 June 2002.

2 INTERGOVERNMENTAL CREDENTIAL AUTHORITY

2.1 INTRODUCTION

The IGCA provides trust through standard security processes by providing authenticated information to enable the privacy of communication. The IGCA is a separate, authenticated, and managed entity that interoperates with existing National Space Agency CAs based on trust agreements between the agencies. This is implemented via the addition of an IGCA root certificate to their trust stores.

2.2 PRIVATE KEY ENCRYPTION AND ITS RELATION TO A CA

Asymmetric keys are the basis of operational security on the Internet. The IGCA leverages this functionality, along with the vetting processes already provided by commercial CAs, for a large-scale deployment to space assets. As will be described in subsequent subsections, the CA performs a primary bridging function between Agencies and other organizations. Figure 2-1 illustrates the CA relationship to asymmetric keys and how authentication and privacy between two parties is ensured.

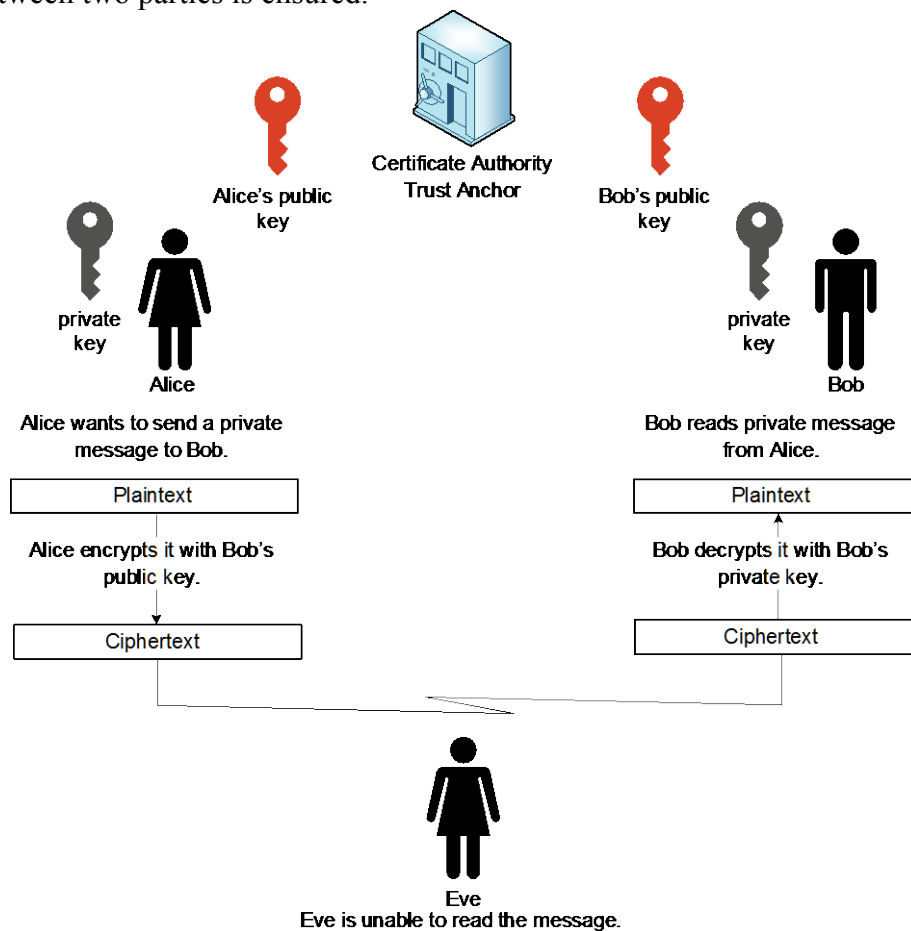


Figure 2-1: Asymmetric Key Use in Relation to a Certificate Authority

2.3 IGCA CONCEPT

This Experimental Specification specifies policy and specifies requirements for an integrated set of technologies, protocols, identity verification, management, and auditing that are necessary for the IGCA and affiliated CAs to issue and manage trusted certificates. The concept of operations depicted in figure 2-2 illustrates the IGCA's use in a terrestrial environment.

The IGCA uses standard internet protocols created by the Internet Engineering Task Force and standards developed by CCSDS to interact with subordinate CAs and nation-state Bridge CAs. The simplified concept of operation is shown without showing the built-in redundancies that are needed for fail-safe operations. The IGCA provides trust and PKI keys that can be used to facilitate the operation of CCSDS security protocols or secured service interfaces. This document specifies the requirements for a Certification Practice Statement (CPS), which is used to govern the operation of CAs. The figure illustrates the functions and interactions facilitated by the IGCA. As a trust anchor it is the source of trusted certificates, and by way of contacts, vetting, and review of security operations, it can subsequently support cross-organization authentications in this way. The IGCA facilitates provisioning of identity services and therefore allowing a more efficient realization of security for protocols between different users and systems compared to the current treaty or single-use agreements.

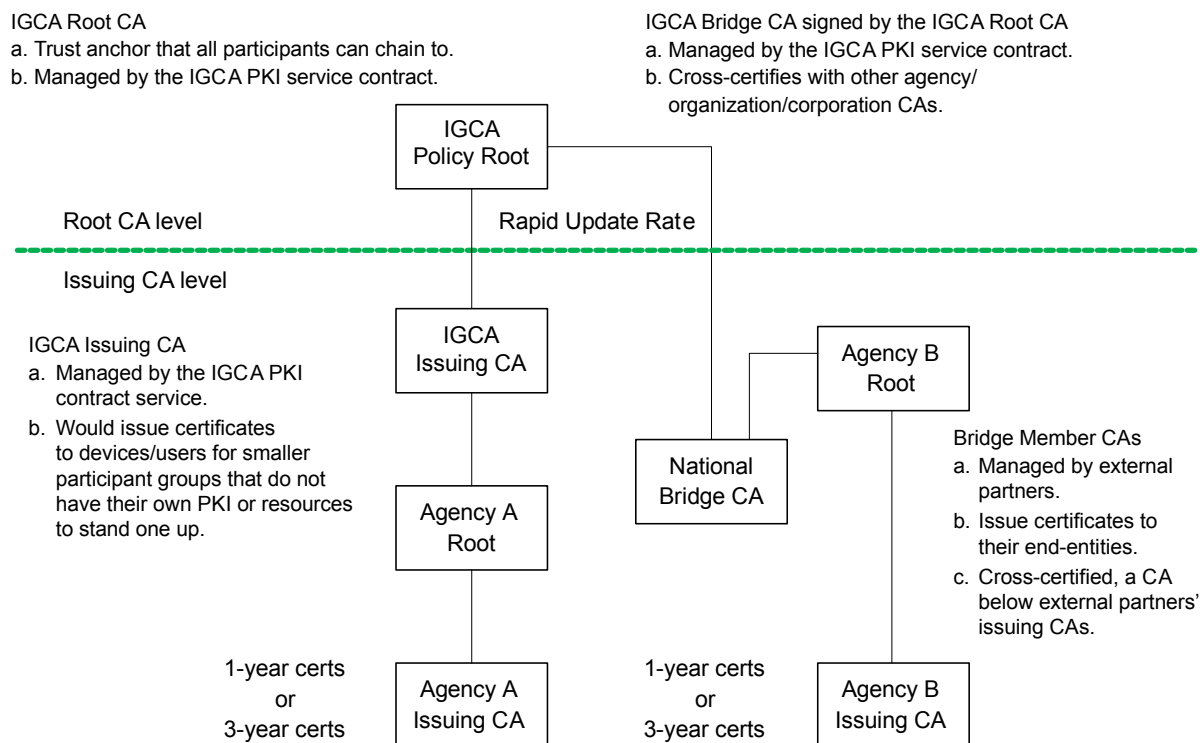


Figure 2-2: IGCA Operations Enable the Security Interconnection Services

IGCA certificates can be used for authentication, confidentiality, and nonrepudiation in a space PKI. The IGCA may be required to perform functions independently, such as cross-signing to other Root CAs, or in conjunction with an international trust anchor (once one is developed), thereby increasing the reach of the IGCA certificates and users.

All certification paths start with a trust anchor/Root CA. A trust anchor certificate:

- is self-signed, that is, signed with the private key corresponding to the public key contained in the subject public key field of the certificate;
- contains any needed parameters in the Subject Public Key Info field, for when the digital signature algorithm used in the certificate requires the use of parameters;
- contains few or no extensions; and
- is transferred to the relying party in an authenticated manner: the signature on the trust anchor certificate cannot authenticate the certificate.

The trust anchor/Root CA must be created and verified such that it can be implicitly trusted. As a trust anchor, the IGCA policy functions will verify each subscriber's identity information. Authentication and identity verification are specified by the IGCA CPS. In general, the activities of the IGCA include, but are not limited to:

- in-person identity verification;
- verification and validation of identity documents;
- enrollment and registration;
- certificate issuance;
- certificate usage;
- certificate revocation; and
- post-issuance updates and additions.

2.4 IGCA DESCRIPTION

The IGCA is the central certification authority that provides the basis for a CCSDS-wide PKI to support universal international mission security without usurping an individual national certificate or key management controls. The IGCA reduces the years of negotiation between nation states and corporations that currently takes place by establishing a centralized organization to vet and disseminate public keying materials. A PKI greatly increases the authentication capacity of the CCSDS community, enhancing trust in interactions, but also allows greater granularity in applying security controls. The IGCA fosters an environment of trusted cooperation and interoperability. The IGCA is a centralized management authority to perform needed policy and maintenance activities.

IGCA functions include acting as the Root CA (trust anchor), Bridges with the National Bridge CA, Subordinate/Issuing CA, Policy CA, Registration CA, Local Mirror, and providing combined operational functions for off- world IGCA System use. (See figure 2-3 for definitions of the independent functions performed by the IGCA.)

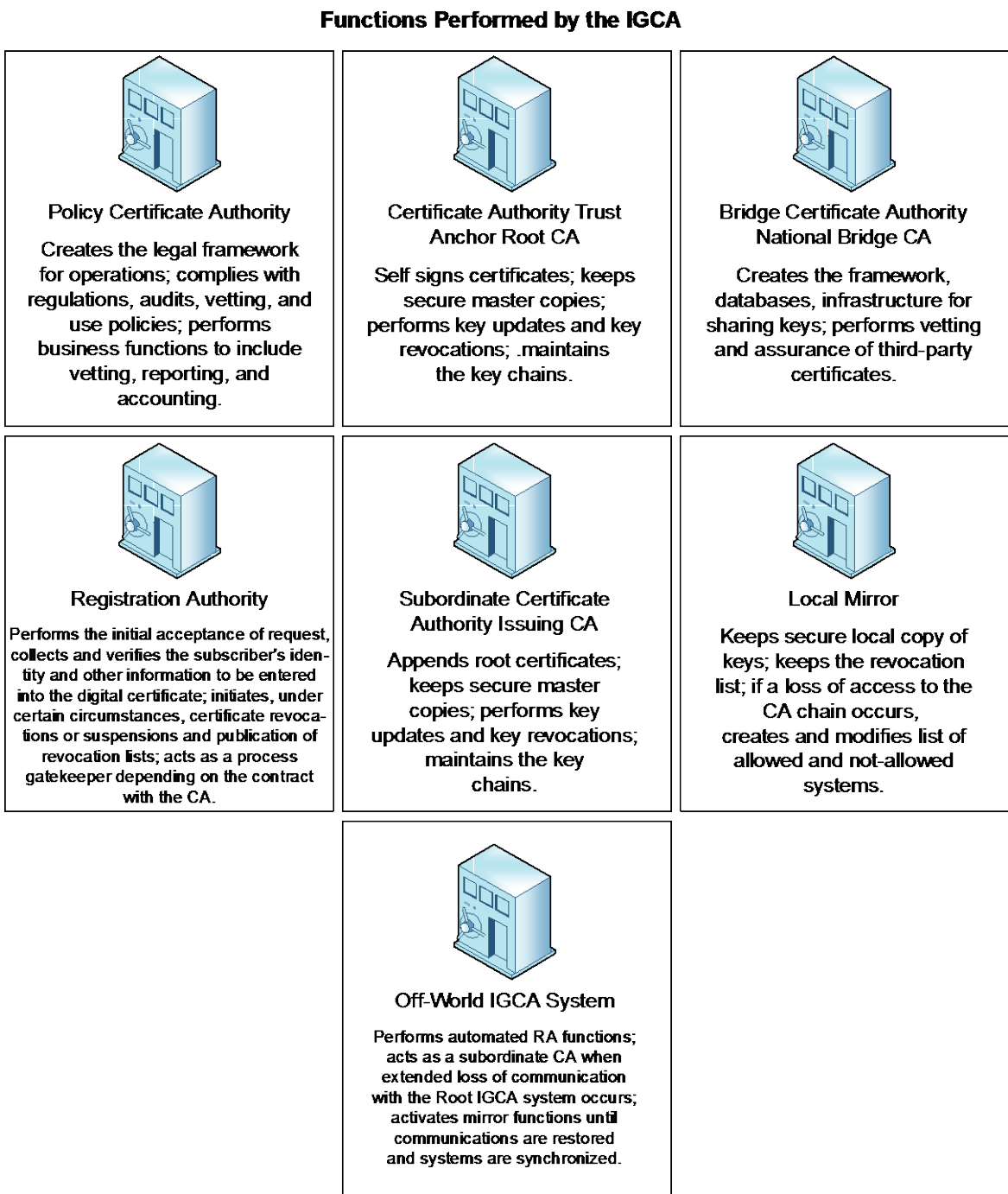


Figure 2-3: Illustration of the CA Functions and Their Operational Use

The Root CA creates and signs certificates. To provide trust for public keys, the Root CA cryptographically signs certificates, which provides assurance that the information contained in the certificate is valid, authentic, and bound to a subject.

2.5 GENERAL CONSTRAINTS

Space communications may suffer from limited bandwidth and transmission delays. Space missions historically are relatively long-lived as compared with terrestrial systems and are not easily modified or upgraded after launch. Space is a uniquely harsh operating environment with radiation, thermal, shock, and vibrational effects. The overall mission, the processors, memory, and communications bandwidth must be taken into consideration with respect to the lifespan of the mission and potential cryptographic upgrades.

Space environmental constraints may affect the operation of the IGCA. Certificate updates and certificate revocations are two of the most critical operations to maintain security. Current terrestrial certificates are issued annually with a move towards shorter certificate validity periods to limit the attack window in the event of certificate compromise. Because of limited contact periods, low bandwidth links, limited memory, and limited processor capabilities in comparison to most terrestrial systems, update rates and processes may vary from what is the norm for terrestrial certificates.

2.6 POST-QUANTUM ENCRYPTION CONSIDERATIONS

Quantum computers, when materialized, will allow exponential speed-up of solving the mathematical problems used by typical asymmetric cryptography, resulting in recovering the keys even in a few hours. Conversely, symmetric ciphers, like the Advanced Encryption Standard, used typically for encryption and encrypted authentication, are less affected (using keys of 256-bit length is considered sufficient to mitigate the threat of quantum computers to symmetric cryptography).

Asymmetric cryptography is used for authentication and digital signatures, as well as for key exchange and key authentication and digital signatures. Since PKI implementations heavily rely on asymmetric cryptography (e.g., for authentication, digital signatures of certificates), all current PKI solutions will be at risk when quantum computers materialize. Even if it will take several years until this happens (experts put it in the range of 10 to 30 years), the migration time (including the length time to design, develop, validate, qualify, and deploy) of space systems and their lifetime force consideration of the quantum threat to cryptography (and specifically to asymmetric cryptography algorithms such as RSA (reference [18]) and Diffie-Hellman (reference [17])). As a result, the IGCA needs to remain cognizant of the adoption of post-quantum-safe algorithms by CCSDS.

Post Quantum Cryptography (PQC) provides asymmetric cryptographic schemes that are quantum resistant. Several PQC algorithms have already been standardized by the National Institute of Standards and Technology (NIST), and more are expected to follow. However, PQC solutions typically require more processing power and memory; moreover, the keys

(public/private) and the signatures can become very lengthy, making multiple fragmentation inevitable. The standardization of quantum-resistant PKI is still at an infancy, and more efforts, studies, and testing are needed before a quantum-resistant PKI solution is standardized.

During the future transition period, post-quantum algorithms will not be supported by all systems. Therefore various migration considerations must be taken into account, including backwards compatibility to continue supporting existing implementations that will not yet have been updated to support the post-quantum algorithms.

3 REQUIREMENTS

3.1 OVERVIEW

In order to trust each other's communications, interagency communications require the use of the trust-anchor method to authenticate their communications. Legal statutes were reviewed based on the information held and expected to transit the communications networks, and it was determined that that information is not classified, and that the highest classification is Sensitive but Unclassified/Controlled Unclassified Information. The following requirements are specific for this trust level.

NOTE – The term 'The IGCA and affiliated CAs' means that the IGCA is the policy/Root CA and the affiliated CAs are the CAs that issue certificates that are tied to the IGCA policy/Root CA.

3.2 POLICY REQUIREMENTS

3.2.1 Each agency shall use IGCA subordinate issuing CAs or cross-certified related issuing CAs.

3.2.2 The IGCA and affiliated CAs shall maintain insider threat monitoring and a mitigation policy.

3.2.3 The IGCA and affiliated CAs shall maintain a vulnerability management plan.

3.2.4 The IGCA and affiliated CAs shall maintain a patch management plan.

3.2.5 The IGCA and affiliated CAs shall maintain a continuity of operations plan.

3.2.6 The IGCA and affiliated CAs shall have a privacy plan that applies to a participant's activities.

NOTE – The Plan is governed by applicable laws or policies.

3.2.7 The IGCA and affiliated CAs shall have the capability of being audited manually and automatically.

NOTES

1 The IGCA is auditable by CCSDS member agencies.

2 The IGCA governing policies are agreed upon by consensus in CCSDS by the member agencies.

3.2.8 The IGCA and affiliated CAs shall follow the ISAE 3000 for audit reporting (reference [6]).

3.2.9 The IGCA and affiliated CAs shall follow *WebTrust Principles and Criteria for Certification Authorities* for audit exclusions (reference [4]).

3.2.10 The IGCA shall allow each agency to apply for certificates.

3.2.11 The IGCA may cross-certify with Root CAs of nation states or corporative CAs.

NOTE – The arrangement between the IGCA and CAs is based on the acceptance of the others security procedures and practices.

3.2.12 The IGCA and affiliated CAs shall have an approved enhanced-vetting process and provide a level of assurance equal to or greater than level of assurance 3 in ISO/IEC 29115:2013 (reference [7]).

3.2.13 The IGCA and affiliated CAs shall maintain an agreed certificate management process.

NOTE – This process would include items such as physical security, environmental controls, system integrity controls, configuration management, integrity management of trusted code, malware detection/prevention, network security and firewall management, port restrictions, address filtering, user management, trusted roles, education awareness, training, logical access controls, activity logging, inactivity time-outs, and individual accountability. In addition, the certificate management and certificate monitoring are sufficient for preventing unmanaged certificate expiration.

3.2.14 The IGCA and affiliated CAs shall maintain an agreed security program and conduct annual risk assessments.

NOTE – The risk assessment includes items such as identifying foreseeable internal and external threats that could result in an unauthorized access, disclosure, and misuse alteration or destruction of certificate data or certificate management processes. It might also include a process to assess the likelihood and potential damage of threats and to assess the sufficiency of the certificate data and the certificate management processes, systems, technologies, and arrangements to counter threats.

3.2.15 The IGCA and affiliated CAs shall create and maintain security log files.

NOTE – The security logs are used to confirm that all system actions can be attributed to an authenticated identity of a person or an automated process.

3.2.16 The IGCA and affiliated CAs shall use domain validation.

NOTE – Domain validation ensures against Man in the Middle (MitM) attacks. DNS validation prevents certificate mis-issuance due to DNS hijacking.

3.3 QUALITY REQUIREMENTS

3.3.1 The Root-CA shall replace its certificate according to its security policy.

NOTE – IGCA Root-CAs are updated based on threat and vulnerability assessments, which are then put into the security policy.

3.3.2 IGCA and affiliated CAs shall maintain 99.982 percent up time.

NOTES

1 Availability/reachability of 99.982 percent is a loss of operations of no more than 1.6 hours per year. Distributed Denial of Service (DDoS) attacks against the IGCA are included in the threat scenarios and should be considered in the performance parameters of the service-level agreement.

2 The availability requirement is bound to the ability to issue new certificates and validate existing certificates.

3.3.3 The IGCA and affiliated CAs shall have reviewed and agreed-upon operational protection policies.

NOTE – The policies are intended to ensure that there are checks and balances to defend against attempts to insert misinformation at any point in the certificate issuing processes.

3.3.4 The IGCA and affiliated CAs shall have two or more mirror sites.

NOTE – Mirrors are identical replicas of the IGCA for load balancing, speed, availability, and back-up purposes.

3.3.5 The IGCA and affiliated CAs

- a) shall use CRLs;
- b) may use additional certificate revocation mechanisms.

3.3.6 The IGCA and affiliated CAs should implement Automatic Certificate Management Environment (ACME) (reference [9]).

3.3.7 The IGCA and affiliated CAs' mirrors shall be geographically and logically diverse.

3.3.8 The IGCA and affiliated CAs' mirrors should comprise different technical solutions.

NOTE – The systems are expected to be totally independent solutions (e.g., different data centers, technical solutions, software, hardware, etc.) for increased reliability of the IGCA architecture.

3.3.9 The IGCA and affiliated CAs' mirrors shall maintain the same configuration between all addressable instances.

3.3.10 The IGCA and affiliated CAs shall maintain configuration control documentation with description and revisions.

3.3.11 The IGCA and affiliated CAs shall use the CCSDS certification structure as outlined in reference [3].

NOTE – Reference [3] provides the specification for the structure of the credentials to be used for authentication by CCSDS-compliant missions and ground systems.

3.3.12 The IGCA and affiliated CAs shall issue a certificate revocation within 24 hours of detection of a compromised credential.

3.3.13 IGCA and affiliated CAs shall issue end-entity certificate lifetimes of two lengths, one year or three years in duration.

NOTE – Shorter lifetimes are desirable for enhanced security. However, for space, the certificate exchange process is over a limited-bandwidth channel and may require several transmissions to validate proper installation. It is envisioned that near-Earth missions would use one-year certificates and deep-space missions would use three-year certificates. Nodes supporting both missions could have both types of certificates.

3.3.14 IGCA and affiliated CAs' end-entity certificate shall be issued 30 days prior to the end of the certificate lifetime.

3.3.15 The IGCA and affiliated CAs may allow the use of overlapping end-entity certificates for up to 30 days.

NOTE – Transmission delays and intermittent contact may require both an old and current certificate to be operational during the same time, because of the requirement to be able to command updates and key changes.

3.3.16 The IGCA and affiliated CAs shall use the *CCSDS Authentication Credentials* IPsec profile (see reference [3]).

3.3.17 The IGCA and affiliated CAs shall use 256-bit keys and RSA Digital Signatures of at least 7680 bits as specified in *CCSDS Cryptographic Algorithms* (reference [8]).

3.3.18 The IGCA and affiliated CAs must support key protection mechanisms as required in FIPS 140-3 or equivalent standards to protect the CA keys (reference [10]).

NOTE – FIPS 140-3 Cryptographic Module Validation Program (CMVP) utilizes the ISO/IEC 19790:2012 requirements standard and ISO/IEC 24759:2017 derived test methods. This requirement is to prevent or recognize compromise of cryptographic modules and cryptographic keys. Example of tamper detection includes tamper-evident coatings or seals that must be broken to attain physical access to the plaintext cryptographic keys and critical security parameters within the module, or pick-resistant locks on covers or doors to protect against unauthorized physical access.

3.3.19 The IGCA and affiliated CAs shall have physical security mechanisms to provide a high probability of detection of attempts at physical access or modification of the cryptographic module.

NOTE – The physical security mechanisms might include the use of anti-tamper enclosures and tamper-detection/response circuitry that zeroes all plaintext Critical Security Parameters (CSPs) when the removable covers/doors of the cryptographic module are opened.

3.3.20 The IGCA and affiliated CAs shall use the Space Assigned Numbers Authority (SANA) registry for Organizations, Contacts, Roles, Contents, and Space Link Identifiers.

NOTE – IDs are located in the registries; information structure/formats and object identifier numbers are specified.

3.3.21 Registration Authorities (RAs) shall be subordinate to the IGCA Root CA or an agency Root CA (reference [13]).

3.3.22 An RA may perform the functions of its master CA except issuing or signing certificates.

NOTE – It is envisioned that at remote locations, for example, Mars, an RA will be used to provide the services for the CA.

3.4 TECHNICAL VETTING REQUIREMENTS FOR ISSUING CAs

3.4.1 IGCA-affiliated CAs shall validate the identity of applicants.

3.4.1.1 The identity source documents shall be bound to that applicant and shall be neither expired nor cancelled.

3.4.1.2 If the two identity source documents bear different names, evidence of a formal name change shall be provided.

3.4.2 The IGCA-affiliated CAs shall use one of the following primary identity source documents in the identity identification process:

- a) government issued proof of identity valid in the CA owner's country;

- b) legally allowed proof of identity accepted by government institutions in the CA owner's country.

3.4.3 The IGCA-affiliated CAs shall use a second source document that must be different from the primary identity source document.

3.4.4 The requirements for proof of identity shall apply to citizens of foreign countries who are working within the resident country.

3.5 OPERATIONAL VERIFICATION

3.5.1 The IGCA, affiliated CAs, and cross-certified CAs shall perform interoperability testing.

3.5.2 The IGCA and affiliated CAs shall test that all the certificates issued are compliant with reference [3].

3.5.3 The affiliated CAs shall confirm the applicant's control of its domain address.

3.6 DOCUMENTATION

The IGCA and affiliated CAs' documentation shall be auditable by CCSDS.

NOTES

- 1 Privacy of individuals is governed by applicable laws.
- 2 Documentation includes policies, procedures, and compliance records.

ANNEX A

IMPLEMENTATION CONFORMANCE STATEMENT PROFORMA

(NORMATIVE)

A1 INTRODUCTION

A1.1 OVERVIEW

This annex provides the Implementation Conformance Statement (ICS) Requirements List (RL) for an implementation of IGCA. The ICS for an implementation is generated by completing the RL in accordance with the instructions below. An implementation claiming conformance must satisfy the mandatory requirements referenced in the RL.

A1.2 ABBREVIATIONS AND CONVENTIONS

CRL distribution point: A directory entry or other distribution source for CRLs. A CRL distributed through a CRL distribution point may contain revocation entries for only a subset of the full set of certificates issued by one CA or may contain revocation entries for multiple CAs. It is a managed parameter within the X.509 credential.

A1.3 CONFORMANCE

The RL consists of information in tabular form. The status of features is indicated using the abbreviations and conventions described below.

Item Column

The item column contains sequential numbers for items in the table.

Feature Column

The feature column contains a brief descriptive name for a feature. It implicitly means “Is this feature supported by the implementation?”

Status Column

The status column uses the following notations:

- M mandatory
- O optional
- C conditional
- X prohibited
- I out of scope
- N/A not applicable

Support Column Symbols

The support column is to be used by the implementer to state whether a feature is supported by entering Y, N, or N/A, indicating:

- Y Yes, supported by the implementation
- N No, not supported by the implementation
- N/A Not applicable

The support column should also be used, when appropriate, to enter values supported for a given capability.

A1.4 INSTRUCTIONS FOR COMPLETING THE REQUIREMENTS LIST

An implementer shows the extent of compliance to the Experimental Specification by completing the RL; that is, the state of compliance with all mandatory requirements and the options supported are shown. The resulting completed RL is called an ICS. The implementer shall complete the RL by entering appropriate responses in the ‘support’ or ‘values supported’ column, using the notation described in A1.3. If a conditional requirement is inapplicable, N/A should be used. If a mandatory requirement is not satisfied, exception information must be supplied by entering a reference X_i , where i is a unique identifier, to an accompanying rationale for the noncompliance.

A2 ICS PROFORMA FOR INTERGOVERNMENTAL CERTIFICATION AUTHORITY (CCSDS 357.1-O-1)

A2.1 GENERAL INFORMATION

A2.1.1 Identification of ICS

Date of Statement (DD/MM/YYYY)	
ICS serial number	
System Conformance statement cross-reference	

A2.1.2 Identification of Implementation Under Test

Implementation name	
Implementation version	
Special Configuration	
Other Information	

A2.1.3 Identification of Supplier

Supplier	
Contact Point for Queries	
Implementation Name(s) and Versions	
Other information necessary for full identification, e.g., name(s) and version(s) for machines and/or operating systems;	
System Name(s)	

A2.1.4 Identification of Specification

CCSDS 357.1-O-1	
Have any exceptions been required?	Yes [] No []
NOTE – A YES answer means that the implementation does not conform to the Recommended Standard. Non-supported mandatory capabilities are to be identified in the ICS, with an explanation of why the implementation is non-conforming.	

A2.2 REQUIREMENTS LIST

Item	Feature	Reference	Status	Support
1	IGCA subordinate usage.	3.2.1	M	
2	Insider threat monitoring/mitigation policy.	3.2.2	M	
3	Vulnerability management plan.	3.2.3	M	
4	Patch management plan.	3.2.4	M	
5	Continuity of operations plan.	3.2.5	M	
6	Privacy plan.	3.2.6	M	
7	Auditing.	3.2.7	M	
8	ISAE 3000 audit reporting.	3.2.8	M	
9	Audit exclusions.	3.2.9	M	
10	Agency certificate application.	3.2.10	M	
11	Cross-certification.	3.2.11	O	
12	Enhanced vetting/level of assurance.	3.2.12	M	
13	Certificate management process.	3.2.13	M	
14	Security program/annual risk assessment.	3.2.14	M	
15	Security log files.	3.2.15	M	
16	Domain validation.	3.2.16	M	
17	IGCA Root-CA Lifetime.	3.3.1	M	
18	Up time.	3.3.2	M	

EXPERIMENTAL SPECIFICATION FOR INTERGOVERNMENTAL CERTIFICATION AUTHORITY

Item	Feature	Reference	Status	Support
19	Operational protection policies	3.3.3	M	
20	Mirror sites.	3.3.4	M	
21	CRLs.	3.3.5	M	
22	ACME.	3.3.6	O	
23	Geographical/logical diversity of mirrors.	3.3.7	M	
24	Mirror technical solutions.	3.3.8	O	
25	Configuration between all addressable instances.	3.3.9	M	
26	Configuration control documentation.	3.3.10	M	
27	CCSDS certification structure.	3.3.11	M	
28	Certificate revocation.	3.3.12	M	
29	End-entity certificate lifetimes.	3.3.13	M	
30	End-entity certificate issuance.	3.3.14	M	
31	Overlapping end-entity use of certificates.	3.3.15	O	
32	IPsec profile.	3.3.16	M	
33	Key/RSA Digital Signatures length.	3.3.17	M	
34	Key protection mechanisms.	3.3.18	M	
35	Physical security mechanisms.	3.3.19	M	
36	SANA registries.	3.3.20	M	
37	RA subordination.	3.3.21	M	
38	Master CA functions.	3.3.22	O	
39	IGCA-affiliated CAs shall validate the identity of applicants.	3.4.1	M	
40	Identity source documents.	3.4.2	M	
41	Second source document.	3.4.3	M	
42	Interoperability testing.	3.5.1	M	
43	Certificate compliance testing.	3.5.2	M	
44	Domain address control.	3.5.3	M	
45	Auditable documentation.	3.6	M	

ANNEX B

SECURITY, SANA, AND PATENT CONSIDERATIONS

(INFORMATIVE)

B1 SECURITY CONSIDERATIONS

B1.1 INTRODUCTION

CCSDS will utilize the credential vetting process and mechanisms to validate the identities of users, applications, and devices.

CCSDS organizations employ technologies to convey identity and to attest to the claims of the trust models that are associated with those identities.

There are risks to CCSDS systems that utilize the IGCA credentials and the credential services; an attacker that gains control of the IGCA credential-management system could issue certificates. A compromised credential management process would result, requiring invalidation of existing certificates and reissuance of all certificates.

A CCSDS IGCA credential-management program would result in higher levels of assurance of the credentials while ensuring interoperability and ease the deployments of systems that are pretested to integrate with the credential-management system. The system would provide unified administration, compliance, and auditing of the X.509 credentials.

B1.2 SECURITY CONCERNS WITH RESPECT TO THE CCSDS DOCUMENT

B1.2.1 Overview

Standard credential service and certificate usage will provide CCSDS missions with a standard means of authentication of communicating entities.

B1.2.2 Data Privacy

Certificates provide a means of identifying/authenticating entities to provide accurate access controls to ensure data privacy.

B1.2.3 Data Integrity

Certificates provide a means whereby data integrity may be provided.

B1.2.4 Authentication of Communicating Entities

Authentication is necessary to ensure that the exchange of information is between intended entities. This document specifies the vetting and certification process requirements for a trusted third party to provide CCSDS-compliant certificates for systems.

B1.2.5 Control of Access to Resources

The identity contained in X.509 certificates is intended to be the basis for assigning access rights to individuals, groups, and system services.

B1.2.6 Availability of Resources

This document deals with the functional requirements needed for a trusted third party to provide or exchange certificates to validate an entity and thus provide assurance that that entity is who or what it espouses to be.

B1.2.7 Auditing of Resource Usage

The CA that generates CCSDS X.509 certificates must be trusted and thus must be auditable by all concerned parties to place trust in the credentials issued. The trust in the certificates and the system is frequently the basis for establishing accountability to specific individuals for actions they have taken on a system. Nonrepudiation of user actions cannot be assured if credentials cannot be assured.

B1.3 POTENTIAL THREATS AND ATTACK SCENARIOS

The CA that generates the certificate and the authenticity of its CCSDS X.509 certificate is dependent upon the digital signature of the CA attesting to the authentication of the credential. If the digital signature algorithm used by the CA is of insufficient cryptographic strength, a credential could be spoofed.

Security Threats against Space Missions (reference [2]) is a CCSDS Informational Report that provides an overview of potential threats against various categories of civilian space missions and provides illustrative security threat data for mission planners. This document should be reviewed.

The IGCA provides vetting, keys, and certificate management and distribution providing mechanisms for authentication, privacy, and non-repudiation.

B1.4 CONSEQUENCES OF NOT APPLYING SECURITY TO THE TECHNOLOGY

If authentication is not implemented, an attacker could inject false or unauthorized commands into a communications path to the spacecraft's command chain and potentially take over control of the spacecraft. This could result in the loss of a mission.

B2 SANA CONSIDERATIONS

This document requires no action from SANA.

B3 PATENT CONSIDERATIONS

There are no known patents that apply to the recommendations in this document.

ANNEX C

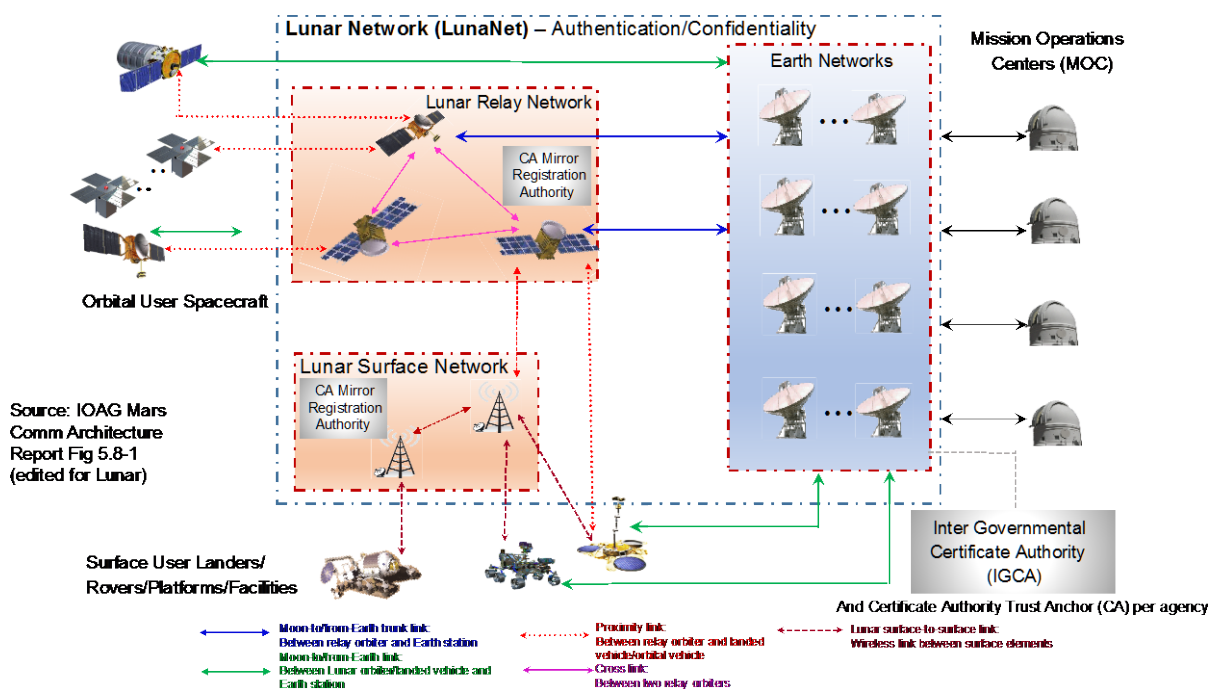
POSSIBLE IMPLEMENTATION EXAMPLE

(INFORMATIVE)

C1 DEPICTION OF A CONCEPTUAL IMPLEMENTATION

C1.1 INTERAGENCY OPERATIONS ADVISORY GROUP'S CONCEPT

Lunar Communications Architecture work is going and it needs a method of validating trust and disseminating certificates and other security functions. The IGCA has been proposed to fill this gap and the graphic below is an overview of how this may be implemented.



ANNEX D

DEFINITION OF ACRONYMS

(INFORMATIVE)

CA	certification authority
CCSDS	Consultative Committee for Space Data Systems
CP	certificate policy
CPS	certification practice statement
CRL	certificate revocation list
ETSI	European Telecommunications Standards Institute
IGCA	intergovernmental certification authority
ISO	International Organization for Standardization
OID	object identifier
PKI	public key infrastructure
RA	registration authority
RFC	Request for Comments